

NAME: OBOLO OLATUNDE ELIJAH
MATRIC NO: 251200096
**COURSE: CYBERSECURITY (DEDICATED
ONLINE)**
**BATCH: CYBER SECURITY DEDICATED
ONLINE JANUARY 2026- (COHORT) —
(CONCORD)**
CAMPUS: IKEJA BRANCH

CYBERSECURITY FINAL PROJECT
Securing a Small Organization from Cyber Threats

Organization: Bright Futures Academy (Small Private School)

Role: Junior Cybersecurity Analyst (Blue Team)

Submitted: 2026

SECTION 1: ASSET IDENTIFICATION

The following table documents all identified assets within Bright Futures Academy. The school operates with approximately 25 staff members and 300 students.

Asset Name	Type	Quantity	Owner/User	Location	Sensitivity
Staff Laptops	End-user Device	20	Teaching Staff	Classrooms/Offices	High
Admin Desktops	End-user Device	5	Admin Staff	Admin Office	High
Student Tablets	End-user Device	50	Students	Computer Lab	Medium
Core Router	Network Component	1	IT Admin	Server Room	Critical
Network Switch	Network Component	3	IT Admin	Network Closets	High
School File Server	Data Asset	1	IT Admin	Server Room	Critical
Student Records DB	Data Asset	1	Admin Staff	Server Room	Critical
Staff Email Accounts	User Account	25	All Staff	Cloud (Google)	High
Student Portal Accts	User Account	300	Students	Cloud/Online	Medium
Wireless Access Points	Network Component	6	IT Admin	Throughout School	High

SECTION 2: THREAT & VULNERABILITY ANALYSIS

The following threat-vulnerability mapping identifies potential attack vectors and corresponding weaknesses within the school's environment.

Threat	Vulnerability	Potential Impact	Affected Assets
Phishing Attack	No email filtering; untrained staff	Credential theft, unauthorized access	Email accounts, file server
Ransomware	Outdated OS, no offsite backup	Total data loss, school disruption	All systems and data
Unauthorized USB Use	No USB control policy enforced	Malware introduction, data theft	Staff laptops, admin desktops
Insider Threat	Excessive user privileges	Data exfiltration, record tampering	Student records DB
Weak Passwords	No password policy enforced	Account compromise, data breach	All user accounts
Man-in-the-Middle (Wi-Fi)	Open or WEP-secured wireless	Interception of student/staff data	Wireless access points
Unpatched Software	No patch management process	Exploitation of known CVEs	All endpoints, server
Social Engineering	Low security awareness among staff	Physical access, data disclosure	Entire organization

SECTION 3: RISK ASSESSMENT

Risk is calculated using the formula: $\text{Risk} = \text{Likelihood} \times \text{Impact}$, where each is scored Low (1), Medium (2), or High (3). Maximum risk score is 9 (Critical).

Risk Scenario	Likelihood	Impact	Score	Level	Priority
Ransomware infection via email	High (3)	High (3)	9	CRITICAL	1 - Top
Phishing leads to credential theft	High (3)	High (3)	9	CRITICAL	2 - Top
Unauthorized access via weak passwords	High (3)	High (3)	9	CRITICAL	3 - Top
Data breach via USB device	Medium (2)	High (3)	6	HIGH	4
Exploitation of unpatched software	Medium (2)	High (3)	6	HIGH	5
Insider data theft by staff	Low (1)	High (3)	3	MEDIUM	6
Wi-Fi interception (MITM)	Low (1)	Medium (2)	2	LOW	7

Top 3 Identified Risks

Risk 1 — Ransomware Infection: Score 9/9. Staff receive emails daily and without filtering or training, a single click can encrypt the entire school network. No backups exist to recover from.

Risk 2 — Phishing / Credential Theft: Score 9/9. Staff have no awareness training. Attackers can impersonate the principal or IT support to steal login credentials and gain full access to student records.

Risk 3 — Weak/Default Passwords: Score 9/9. Without a password policy, staff reuse simple passwords across systems. A single compromised account can cascade into a full organizational breach.

SECTION 4: ENDPOINT SECURITY DESIGN

4.1 Antivirus vs. EDR — Conceptual Comparison

Feature	Antivirus (AV)	Endpoint Detection & Response (EDR)
Detection Method	Signature-based (known threats only)	Behavioral analysis (known + unknown threats)
Response	Quarantine/delete files	Isolate endpoint, kill process, rollback
Visibility	Limited — file scans only	Full visibility — processes, network, memory
Best For	Basic protection, low-budget environments	Organizations handling sensitive data
Recommendation	Deploy AV immediately (e.g., Windows Defender, Malwarebytes)	Upgrade to EDR (e.g., Wazuh) as budget allows

4.2 Patch Management Plan

Weekly: Enable automatic Windows/macOS updates on all staff devices.

Monthly: IT admin reviews and applies server and application patches every first Monday.

Immediately: Critical/zero-day patches (CVSS score 9+) applied within 48 hours of release.

Verification: After patching, IT confirms patch status via Windows Update logs or WSUS report.

4.3 User Privilege Control

Principle of Least Privilege: All standard staff and student accounts operate without administrator rights.

Admin accounts are separate from daily-use accounts; IT admin uses a dedicated admin account only when needed.

Student accounts have read-only access to shared resources; no software installation rights.

Account review: Privileges are audited every 6 months; unused accounts disabled after 30 days of inactivity.

4.4 USB & External Device Policy

USB storage devices are blocked on all school-owned endpoints via Group Policy (GPO) settings.

Exceptions require written IT admin approval and use of encrypted, school-issued USB drives only.

CD/DVD drives are disabled. Bluetooth file transfer is disabled on staff laptops.

Any personal device connecting to the school network must be registered and approved by IT.

SECTION 5: SECURITY POLICIES & BEST PRACTICES

Policy 1: Password Policy

Requirement	Standard
Minimum Length	12 characters minimum
Complexity	Must include uppercase, lowercase, number, and special character (e.g., @, #, !)
Expiry	Passwords must be changed every 90 days
Reuse	Cannot reuse the last 5 passwords
MFA	Multi-Factor Authentication (MFA) is mandatory for all admin and email accounts
Sharing	Password sharing is strictly prohibited. Violation leads to disciplinary action.
Storage	Passwords must be stored in an approved password manager (e.g., Bitwarden). No sticky notes.

Policy 2: Acceptable Use Policy (AUP)

All staff and students using Bright Futures Academy technology resources must comply with the following:

Permitted Uses:

Using school devices for educational, administrative, or school-related work only.

Accessing approved websites and school platforms for learning and productivity.

Reporting suspicious emails, links, or unusual system behavior to IT immediately.

Prohibited Uses:

Installing unauthorized software, games, or browser extensions.

Accessing social media, gambling, or adult content on school networks or devices.

Connecting personal USB drives or unauthorized external devices.
Attempting to bypass network security controls, firewalls, or content filters.
Sharing login credentials with any other person.

Consequences: Violations may result in suspension of access privileges, disciplinary action, or legal consequences depending on severity.

Policy 3: Incident Reporting Policy

All staff and students must report suspected security incidents immediately. Failure to report is itself a policy violation.

What to Report:

Suspicious emails, links, or attachments received.
Devices behaving unusually (slowdowns, pop-ups, unexpected reboots).
Missing or stolen devices.
Unauthorized persons accessing restricted areas or systems.

How to Report:

Call the IT Help Desk: ext. 100 (during school hours).
Email: security@brightfuturesacademy.edu (24/7 monitored).
Complete the Incident Report Form available on the school intranet.

Response Time: IT will acknowledge all reports within 1 hour and begin investigation within 4 hours of notification.

SECTION 6: MONITORING & DETECTION PLAN

6.1 Logs to Collect

Log Type	Source	Purpose
Authentication Logs	Windows Event Log (Event IDs 4624, 4625)	Detect brute force and unauthorized logins
Network Traffic Logs	Router/Firewall logs	Detect unusual outbound connections or scanning
USB/Device Logs	Windows Event Log (Event ID 6416)	Detect unauthorized removable media use

Log Type	Source	Purpose
System/Application Logs	Windows Event Viewer, Sysmon	Detect software crashes, new process creation
Email Logs	Google Workspace Admin Console	Detect phishing attempts and email anomalies
Admin Account Logs	Windows Event Log (Event IDs 4720, 4728)	Detect unauthorized account creation/privilege escalation

6.2 Recommended Monitoring Tools

Wazuh (Free SIEM): Centralizes all logs, generates alerts, and provides a security dashboard. Ideal for this environment.

Sysmon (Microsoft Sysinternals): Provides detailed Windows event logging including process creation, network connections, and file changes.

Wireshark: Network packet analyzer for investigating suspicious traffic. Used during incident investigation.

Google Workspace Admin Console: Built-in monitoring for email security, login activity, and sharing violations.

Windows Defender Security Center: Built-in endpoint protection with basic alerting and threat history.

6.3 Suspicious Activities to Monitor

5 or more failed login attempts on one account within 10 minutes — possible brute force attack.

Login attempts outside school hours (e.g., 11 PM to 5 AM) from staff accounts.

Large file transfers to external IPs or cloud storage services (>100MB at once).

New administrator account created outside of normal IT change management process.

Antivirus detection of malware, even if quarantined — may indicate broader campaign.

Unusual process execution (e.g., PowerShell running encoded commands).

USB device inserted on a restricted machine — triggers immediate investigation.

SECTION 7: INCIDENT RESPONSE PLAN

The following workflows guide the IT team's response to the two most likely incidents in the school environment. All responses follow the standard 4-phase model: Identify → Contain → Eradicate → Recover.

7.1 Malware / Ransomware Infection Response

Phase	Actions	Responsible Party
IDENTIFY	1. Receive alert from AV/EDR or user report. 2. Confirm infection by checking AV logs. 3. Identify affected device(s) and determine malware type.	IT Admin / Wazuh SIEM alerts. Any staff reporting unusual system behavior should call Help Desk immediately.
CONTAIN	1. Immediately disconnect infected device from network (pull cable or disable Wi-Fi). 2. Do NOT shut down — preserve evidence in memory. 3. Block affected IP at the firewall.	IT Admin physically isolates device. Network admin updates firewall rules within 15 minutes of confirmation.
ERADICATE	1. Run full AV/EDR scan on isolated device. 2. Identify and delete malicious files/registry entries. 3. If ransomware: wipe and reimage the device from clean backup.	IT Admin with AV tools. Reimaging should take no more than 4 hours per device.
RECOVER	1. Restore data from last clean backup. 2. Reconnect device to network after verification. 3. Monitor device closely for 72 hours post-recovery.	IT Admin restores from backup. Verify backup integrity before restoration. Document the full incident.

7.2 Phishing Compromise Response

Phase	Actions	Responsible Party
IDENTIFY	1. Staff reports suspicious email or notices unexpected account activity. 2. IT reviews email headers and links to confirm phishing. 3. Check if credentials were entered on phishing site.	Any staff member who receives suspicious email. IT Admin confirms within 30 minutes of report.
CONTAIN	1. Immediately disable/lock compromised account. 2. Revoke active sessions and API tokens. 3. Block the phishing sender domain in email gateway. 4. Warn all staff about the phishing campaign.	IT Admin locks account via admin console. Email admin blocks sender domain within 1 hour.
ERADICATE	1. Reset compromised account password. 2. Enable/re-enroll MFA on the account. 3. Review account activity logs for unauthorized actions taken. 4. Delete any malicious emails from all inboxes.	IT Admin resets credentials. User must confirm new password is strong and unique.
RECOVER	1. Re-enable account with new secure credentials. 2. Notify affected parties if data was accessed. 3. Conduct immediate phishing awareness training for all staff.	IT Admin re-enables account. Principal notified if student/parent data was accessed. Training within 1 week.

SECTION 8: REFLECTION & ETHICS

8.1 Why Ethics Matters in Cybersecurity

Cybersecurity professionals are entrusted with a level of access that very few people in an organization have. An IT admin at Bright Futures Academy can view emails, access student records, monitor network traffic, and control all user accounts. This power, if misused, could cause serious harm — to individuals, to the organization, and to society.

Ethics in cybersecurity means using this access only for its intended purpose: to protect. It means not reading emails out of curiosity, not sharing sensitive data discovered during an investigation, and not exploiting vulnerabilities for personal gain. The entire field of cybersecurity is built on trust — organizations trust their security teams to protect them, and that trust must be honored.

In this project's scenario, student records contain minors' personal information. Accessing, sharing, or mishandling this data — even accidentally — would be both an ethical violation and a legal one under data protection regulations. A security analyst must treat this data with the highest level of care and discretion.

8.2 Professional Behavior of a Security Analyst

Confidentiality: Never discuss investigation details with unauthorized personnel. Security incidents should only be shared on a need-to-know basis.

Integrity: Report findings honestly, even when the findings reflect poorly on the organization or its leadership. An analyst who hides vulnerabilities creates greater risk.

Accountability: Document all actions taken during an investigation. If an error is made, own it and correct it immediately.

Impartiality: Treat every incident objectively. Do not let personal relationships influence how an investigation is conducted.

Continuous Learning: The threat landscape changes daily. A professional security analyst stays current through training, certifications, and following security news and advisories.

Legal Compliance: Never attempt unauthorized access, even to test defenses, without explicit written permission. Unauthorized testing is illegal, even with good intentions.

8.3 Lessons Learned from This Project

This project demonstrated that cybersecurity is not just a technical discipline — it is a comprehensive organizational responsibility. The most significant insight was that people, not technology, are the most critical factor in security. Technical controls like

antivirus and firewalls are important, but a single untrained staff member clicking a phishing link can bypass all of them.

The risk assessment exercise was particularly eye-opening. Translating abstract threats into quantified risk scores made it clear which problems deserved immediate attention versus which could be addressed over time. It also highlighted that some of the most impactful risks — weak passwords and lack of awareness training — are among the cheapest to fix.

The incident response planning section reinforced that preparation is everything. Organizations that have a documented, tested response plan recover from incidents far faster than those that improvise. The exercise of thinking through each phase — identification, containment, eradication, and recovery — for specific scenarios like ransomware and phishing brought a structured, systematic mindset that is central to professional security work.

Overall, this project provided a realistic view of what junior security analysts actually do in the field: not just blocking attacks, but understanding risk, designing controls, writing policies, and planning for when things go wrong. These skills are directly applicable to real-world cybersecurity roles and form the foundation of a strong Blue Team mindset.

REFERENCES & TOOLS

Microsoft Sysmon (Sysinternals) — learn.microsoft.com/sysinternals

CVE Vulnerability Database — cve.mitre.org

Malwarebytes Free Antivirus — malwarebytes.com

Bitwarden Password Manager — bitwarden.com

PhishTool Email Analysis — phishtool.com

Google Workspace Admin Security — admin.google.com

Wireshark Network Analyzer — wireshark.org